

MODULE 4.2: AUDITING

Contents

1. Introduction to Auditing	1
2. Planning an Audit	2
3. Information Security Management System	4
4. Introduction to ISO 27001:2013	5

Introduction to Auditing

- **Auditing:** Auditing in information security refers to the **systematic evaluation** of systems, processes, and controls to ensure they follow security policies, industry standards, and legal requirements. It helps organizations identify weaknesses, measure compliance, improve security, and reduce risk.
- **Audit:** An audit is a **formal, independent, and structured examination** of an organization's information systems, security controls, and processes.

Objectives of an Audit

- **Assess Compliance:** Check whether systems follow policies, procedures, standards, and regulations (ISO 27001, GDPR, PCI-DSS, etc.).
- **Identify Weaknesses:** Detect vulnerabilities, misconfigurations, and gaps in security.
- **Evaluate Controls:** Ensure preventive, detective, and corrective controls are working effectively.
- **Ensure Accuracy & Integrity:** Confirm that data and systems are reliable and protected.
- **Improve Risk Management:** Provide recommendations to reduce risk.
- **Support Accountability:** Ensure employees and IT teams follow approved security practices.
- **Prepare for Legal or Regulatory Requirements:** Maintain evidence for audits, certifications, and investigations.

Types of Audits

1. **IT Audit:** Evaluates the overall IT environment, including hardware, software, networks, backup systems, and operations. Focuses on availability, data integrity, and system performance.
2. **Security Audit:** Examines the effectiveness of an organization's security controls — firewalls, access controls, authentication mechanisms, logs, encryption, and physical security. Goal: ensure confidentiality, integrity, and availability (CIA).
3. **Compliance Audit:** Checks whether the organization follows required laws, policies, and regulations. Examples include ISO 27001, HIPAA, PCI-DSS, and internal company policies.
4. **Threat Audit:** Assesses potential threats to the system by analyzing vulnerabilities, attack vectors, threat actors, and recent security incidents. Often used for risk assessment and threat modelling.
5. **Assessment Audit:** Evaluates current security posture by analyzing risks, controls, vulnerabilities, and processes. Often performed before certification or major system changes.
6. **Validation Audit:** Conducted to verify whether previous audit findings have been addressed and whether implemented controls are functioning as intended. Often used after remediation steps.

Audit Principles

1. **Integrity:** Auditors must be honest, ethical, and unbiased.
2. **Objectivity:** Findings must be based on evidence, not assumptions or personal opinions.
3. **Evidence-Based Approach:** All conclusions should be supported by verifiable documentation, logs, or observations.
4. **Confidentiality:** Audit information must be protected and disclosed only to authorized persons.
5. **Independence:** Auditors should not audit systems they are responsible for managing.
6. **Systematic and Structured Process:** Audits must follow a planned methodology, checklists, and standardized procedures.
7. **Competence:** Auditors must have proper knowledge, skills, and experience in information security and auditing.

Roles and Responsibilities of Auditors

- Plan and prepare the audit process
- Review policies, procedures, and documentation
- Interview employees and IT teams
- Inspect systems, configurations, and controls
- Conduct vulnerability assessments and analyze logs
- Identify gaps, weaknesses, and non-compliance
- Collect and verify evidence
- Prepare audit findings and recommendations
- Deliver the final audit report to management
- Follow up on remediation and corrective actions

Planning an Audit

Audit planning ensures that the audit is performed efficiently, systematically, and in alignment with organizational goals. Good planning helps auditors understand what to check, how to check it, and what evidence is required.

Audit Methodology

Audit methodology refers to the **structured approach** used to conduct an audit from start to finish. It ensures consistency, reliability, and compliance with auditing standards. A typical audit methodology includes:

1. **Planning** – Define audit goals, scope, and approach.
2. **Understanding the Environment** – Study systems, policies, and processes.
3. **Risk Assessment** – Identify major risks and areas needing attention.
4. **Control Evaluation** – Review security controls and processes.
5. **Evidence Collection** – Gather proof through interviews, observations, logs, and tools.
6. **Analysis** – Compare evidence with standards and policies.
7. **Reporting** – Document findings, gaps, and recommendations.
8. **Follow-up** – Verify that corrective actions are implemented.

This structured methodology ensures the audit is accurate and repeatable.

Understanding Audit Criteria

Audit criteria are **benchmarks or standards** against which the organization is evaluated. Common sources of audit criteria include:

- Internal security policies

- ISO 27001 standards
- Regulatory requirements (GDPR, PCI-DSS, HIPAA)
- Industry best practices
- Risk assessment reports
- Legal requirements

Audit criteria define **what to check** and determine **whether controls meet the required standards**.

Scope: The audit scope defines **what systems, departments, networks, applications, and processes** will be audited. It helps avoid unnecessary work and ensures the audit stays focused. Examples of scope:

- Audit only email and authentication systems
- Audit HR database access and backup processes
- Audit the entire network infrastructure

Objectives: Objectives define **what the audit aims to achieve**. Example objectives:

- Evaluate effectiveness of access controls
- Check compliance with ISO 27001
- Detect security gaps and risks
- Verify patch management and backup procedures

Clear scope and objectives make the audit meaningful and manageable.

Preparing Audit Checklists

Audit checklists help auditors follow a **consistent and comprehensive examination**.

A good checklist includes:

- **Policy checks:** Are security policies documented and followed?
- **Access control checks:** Password rules, MFA, user provisioning.
- **System configuration checks:** Firewalls, servers, patch status.
- **Network security checks:** Logs, IDS/IPS, traffic filtering.
- **Physical security checks:** Access entries, CCTV, server room controls.
- **Compliance checks:** ISO 27001 Annex A controls, regulatory standards.

Checklists ensure nothing important is missed and help standardize the audit process.

Gathering Evidence During Audit

Evidence collection is a critical part of an audit because **findings must be backed by proof**. **Types of Evidence:**

- **Documentary:** Policies, logs, screenshots, configurations
- **Physical:** Photos of server rooms, badges, CCTV logs
- **Testimonial:** Interviews with employees and admins
- **Technical:** System scans, configuration outputs, firewall logs

Methods of Gathering Evidence

- Reviewing system logs and audit trails
- Observing processes and operations
- Checking configurations directly on systems
- Interviewing staff and administrators
- Running vulnerability scans or configuration assessments

Evidence must be accurate, relevant, and collected ethically. All evidence should be documented properly and stored securely for audit reporting.

Information Security Management System

An **Information Security Management System (ISMS)** is a structured framework of policies, procedures, and controls designed to **protect an organization's information assets**. It ensures confidentiality, integrity, and availability (CIA) through risk-based controls and continuous improvement. **Purpose of an ISMS**

Key purposes include:

- **Identify and manage risks** to information assets
- **Protect confidentiality, integrity, and availability (CIA)**
- **Ensure compliance** with laws and standards (e.g., ISO 27001, GDPR)
- **Prevent data breaches and security incidents**
- **Establish uniform security policies and controls**
- **Improve organizational resilience** against cyber threats
- **Enhance trust** with customers, partners, and stakeholders

In short, an ISMS provides a **structured approach** to securing information across the organization.

Components of ISMS

An effective ISMS consists of several core components that work together to protect information:

1. **Policies and Procedures:** Documentation that defines how security will be implemented (password policies, access control, backup policies).
2. **Risk Management Framework:** Processes for identifying, analyzing, evaluating, and treating risks.
3. **Asset Management:** Identifying and classifying assets such as data, hardware, software, and people.
4. **Security Controls:** Technical, administrative, and physical controls (firewalls, encryption, training, access controls).
5. **Roles and Responsibilities:** Clear assignment of security responsibilities across departments.
6. **Training and Awareness:** Educating employees about security policies and safe practices.
7. **Incident Management:** Processes for detecting, reporting, and responding to security incidents.
8. **Documentation & Record-Keeping:** Policies, risk registers, logs, audit reports, and asset inventories.
9. **Compliance & Legal Requirements:** Ensuring adherence to standards, regulations, and contractual obligations.

Together, these components form the backbone of an ISMS.

Monitoring, Review, and Continuous Improvement

ISMS follows the **PDCA (Plan–Do–Check–Act)** cycle, meaning it is never static — it must be regularly updated.

Monitoring: Continuous tracking of security controls, logs, audits, and incidents. Examples include:

- Monitoring access logs
- Reviewing firewall rules
- Checking system updates
- Tracking vulnerability scans

Review: Formal reviews ensure the ISMS is functioning correctly. Reviews include:

- Internal audits
- Management reviews

- Risk assessments
- Compliance checks

Continuous Improvement: Based on monitoring and review results, improvements are applied to make the ISMS stronger. This may include:

- Updating policies
- Adding new controls
- Enhancing training
- Improving incident response

Continuous improvement ensures the ISMS adapts to new threats, technologies, and regulations.

Introduction to ISO 27001:2013

- ISO 27001:2013 is an **international standard** for establishing, implementing, maintaining, and continually improving an **Information Security Management System (ISMS)**.
- It defines requirements for protecting an organization's information assets through a systematic, risk-based approach.
- ISO 27001 is a globally recognized standard published by ISO (International Organization for Standardization).
- It outlines **mandatory requirements** for setting up an ISMS and includes a set of security controls (Annex A) to manage risks.

The main purposes of ISO 27001 are to:

- Establish a structured **framework for protecting information**
- Ensure **confidentiality, integrity, and availability (CIA)**
- Implement **risk-based security controls**
- Ensure compliance with laws, regulations, and security policies
- Reduce the likelihood and impact of cyber attacks
- Demonstrate security assurance to customers and stakeholders
- Improve security culture in organizations

In short, ISO 27001 helps organizations **manage information risks effectively and systematically**.

Key Clauses and Structure

ISO 27001 consists of **10 major clauses**, of which **Clauses 4 to 10 are mandatory** for ISMS implementation. These clauses form the **Plan-Do-Check-Act (PDCA)** cycle, which provides the framework for the ISMS:

Clause	Title	Purpose
Clause 1	Scope	Describes what the standard covers
Clause 2	Normative References	Supporting ISO standards
Clause 3	Terms & Definitions	Definitions of ISO terminology
Clause 4	Context of the Organization	Understanding internal and external issues and the needs of interested parties to define the ISMS scope.
Clause 5	Leadership	Senior management commitment, setting the security policy, and defining roles/responsibilities.
Clause 6	Planning	Establishing the risk assessment process , identifying risks, and selecting security objectives.

Clause 7	Support	Ensuring resources, competence, awareness, communication, and documented information are managed.
Clause 8	Operation	Implementing the risk treatment plan, which involves executing the controls chosen from Annex A.
Clause 9	Performance Evaluation	Monitoring, measuring, analysis, internal audits, and management review of the ISMS.
Clause 10	Improvement	Continually improving the ISMS based on findings from audits and reviews.

Annex A Security Controls

- Annex A contains **114 security controls** grouped into **14 control domains**.
- These controls help organizations address security risks identified during risk assessment.
- These controls are selected based on the organization's risk levels and security needs.

Certification Process and Compliance Requirements

Becoming ISO 27001 certified involves proving that the organization has a functioning ISMS aligned with the standard.

Steps in Certification Process

1. **Gap Analysis:** Identify what is missing compared to ISO requirements.
2. **ISMS Implementation:** Develop policies, risk assessment, controls, and documentation.
3. **Internal Audit:** Check whether the ISMS is functioning correctly.
4. **Stage 1 Audit (Document Review):** External auditors review ISMS documentation.
5. **Stage 2 Audit (On-site Audit):** Auditors verify implementation, interview staff, inspect controls.
6. **Certification Decision:** If compliant, the organization receives ISO 27001 certification.
7. **Surveillance Audits (Yearly):** Ensures the ISMS is still maintained.
8. **Recertification (Every 3 Years):** Full audit to ensure long-term compliance.

Compliance Requirements

To comply with ISO 27001, an organization must:

- Maintain a documented ISMS
- Conduct regular risk assessments
- Implement appropriate Annex A controls
- Keep evidence of processes, logs, policies, and audits
- Train employees and ensure awareness
- Continuously monitor, review, and improve the ISMS
- Maintain incident response and business continuity processes

Compliance ensures strong information security practices across the organization.